Form FP-1

Department of Computer Science Batch Fall 2026

Proposal Form for the Final Year Project

1. **Title:** **GOVERNOR-OT:** Rule-Based Command Validation for LLM-Driven Security Testing in Industrial Networks

2. **Domain(s):**
- [Artificial Intelligence]
- [Networking]
- [Cybersecurity]

3. **Nature:** ☒ Extension of Existing Project

4. **Brief Outline:**

GOVERNOR-OT extends VEXA_IoT (Swinea, Aryal, Praharaj & Gupta; arXiv:2607.09653v1, Jul. 2026) [1], a two-agent framework in which one agent scans and plans and the other executes attacks on IoT targets using nmap and searchsploit. It reached a 95.0% success rate over 260 trials on the IoTGoat and Metasploitable2 testbeds [1].

The paper's own results show three gaps. Of 200 IoTGoat attempts, 11 failed from model refusal, repeated syntax errors or hallucination, and nothing checks a command before it runs [1, Table IV]. Every attack used a paid commercial model (ChatGPT 5.1 thinking) at 460 to 1,480 tokens each [1, Table V]. The authors themselves list stronger command validation and safety controls as future work [1, Sec. V]. GOVERNOR-OT adds a deterministic, non-AI Safety-Critic between the Planner and Executor and runs the model locally. Whether reliability holds with a smaller model will be tested in our own benchmarks [2]–[6].

5. **Objectives:**

This project aims to:

- Build an AST-based Safety-Critic that checks every Planner command before it reaches the target, aimed at the 11 of 200 execution failures in VEXA_IoT [1, Table IV].
- Replace the commercial cloud LLM with a local open-weight model (Llama-3-8B or Qwen-2.5) served through Ollama, removing the per-scan API cost [1, Table V].
- Build a live dashboard showing each command as it moves from Planner to Safety-Critic to Executor, in place of the baseline's command-line logs [1, Sec. III-A].
- Benchmark safety catch rate, execution reliability and per-scan cost against the baseline's Tables III–V on a comparable subset of scenarios. A local 8–14B model and a commercial one are not an exact like-for-like comparison.
- Extend testing, in simulation, to constrained industrial-style protocol scenarios beyond the general IoT/Linux testbeds in [1].

6. Scope:

In scope: a Planner/Executor pair like VEXA_IoT's [1, Sec. III], an AST-based Safety-Critic, local hosting through Ollama and a real-time dashboard. Testing will use a setup comparable to the baseline's IoTGoat/Metasploitable2 environment [1, Sec. IV-A] plus Modbus TCP scenarios on a Dockerised PyModbus PLC testbed.

Out of scope: real physical industrial hardware (SCADA/PLC/Modbus). The baseline does not test it either [1, Sec. IV-A], so our industrial-setting results come from simulation only.

7. Proposed Methodology:

GOVERNOR-OT keeps VEXA_IoT's two-agent core, a Planner that decides what to attack and an Executor that carries it out [1, Sec. III], and adds one deterministic step between them:

- Reconnaissance: nmap and searchsploit results go to the Planner, as in the baseline [1, Sec. III-C].
- Command generation: the Planner, running locally on Llama-3-8B or Qwen-2.5 via Ollama, proposes a command.
- Safety-Critic check: the command is parsed into an Abstract Syntax Tree and checked against a fixed rule set by ordinary code, not a second AI model. A rule-based static check finished in under two seconds in [5].
- Correction loop: a blocked command returns to the Planner with the exact rule it broke, so it can be fixed. This targets the repeated identical failures in the baseline's retries [1, Table IV].
- Execution and validation: an approved command runs through the Executor, which reports the outcome back using the baseline's success and retry logic [1, Sec. III-C/D].

A pre-execution check is needed because [3] found substantial unsafe behaviour in LLM agents (average ASR of 47.1% across 1,072 scenarios and 12 agents). The closest existing safety layer, TrustAgent [2], uses an LLM (GPT-4) as its safety inspector, so it can fail the same way as the agent it checks. A deterministic Safety-Critic addresses that gap. Local hosting is reasonable because [4] reports a fine-tuned 14B model beating DeepSeek-R1 (671B), Gemini 2.5 Pro and OpenAI o3 on recovery time and hallucination in incident-response planning.

8. Resources Involved:

- Software: Ollama with Llama-3-8B or Qwen-2.5; Docker; nmap, searchsploit, bettercap and John the Ripper, as in the baseline [1, Sec. IV-A2]; a Python/Node.js AST parser; React for the dashboard.
- Hardware: a local GPU, or a cloud runtime (Groq LPU API or Google Colab) through Ollama, running an open-weight 8–14B model. On a local GPU the per-scan cost is electricity only [6].
- Test environment: an isolated attacker/client/target testbed like the baseline's [1, Sec. IV-A2], plus a Dockerised PyModbus testbed simulating Modbus TCP PLCs.
- Literature base: the baseline paper [1] and five supporting sources [2]–[6], listed in the References.

9. Final Outcomes/ Deliverables:

- A working GOVERNOR-OT prototype (Planner, AST-based Safety-Critic, Executor) running on a local model.
- A live dashboard showing approved and blocked commands, with rule toggles, audit logs and a cost view.
- A Safety-Critic rule set covering scenarios comparable to the baseline's 10 attacks [1, Table II].
- A benchmarking report comparing safety catch rate, reliability and cost with the baseline's Tables III–V [1].
- A final report, documentation and a live demo.

10. Learning Outcomes:

- Building and orchestrating a multi-agent LLM pipeline for a security task.
- Deterministic, non-AI validation (AST-based static analysis) compared with AI-based safety checking [2], [5].
- Deploying and costing local open-weight LLM inference [4], [6].
- Offensive security tools (nmap, searchsploit, bettercap) and the OWASP IoT Top 10 [1].
- Building a real-time monitoring and audit dashboard.
- Designing a reproducible benchmark against a published baseline.

11. Industrial Support (If any):

Mentorship and technical advice from Mr. Umair Ali (Manager of Data & Digital Delivery, National Foods Limited). No direct funding. GOVERNOR-OT is an academic extension and benchmark of a recent baseline paper [1].

12. FYDP to Sustainable Development Goals (SGDs) Mapping:

SGDs	Mapping	Description
SDG 01. No poverty		
SDG 02. Zero hunger		
SDG 03. Good health and well-being		
SDG 04. Quality		
education		
SDG 05. Gender equality		
SDG 06. Clean water and sanitation		
SDG 07. Affordable and clean energy		
SDG 08. Decent work and economic growth		

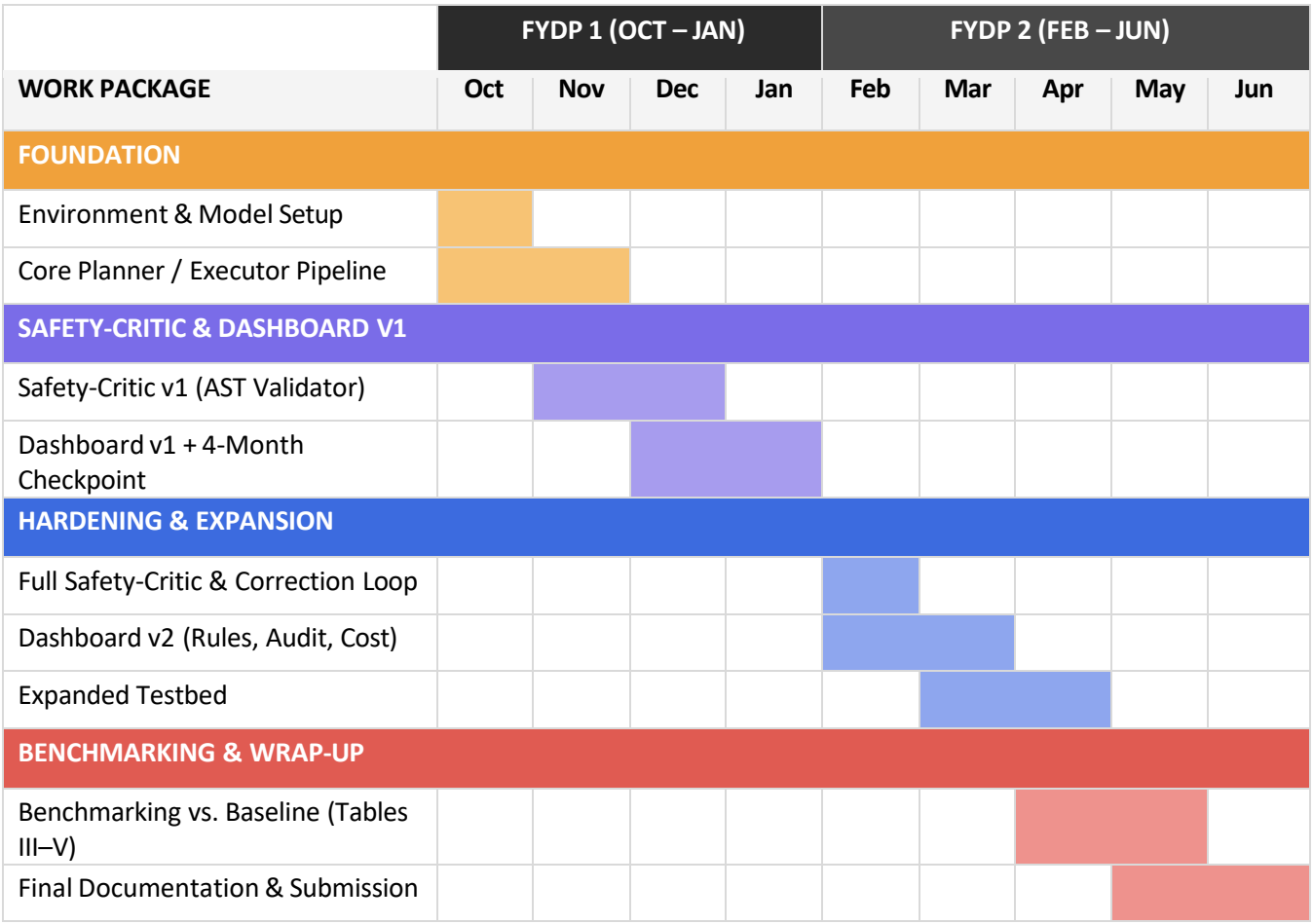
SDG 09. Industry, innovation, and infrastructure	✓	Provides low-cost, deterministic vulnerability testing that supports more resilient digital and IoT infrastructure.
SDG 10. Reduced inequalities		
SDG 11. Sustainable cities and communities		
SDG 12. Responsible consumption and production		
SDG 13. Climate action		
SDG 14. Life below water		
SDG 15. Life on land		
SDG 16. Peace, justice and strong institutions	✓	Proactive, deterministic security auditing of networked and IoT systems reduces exposure to cyberattacks that threaten organizations and the public.
SDG 17. Partnerships for the goals		

13. FYDP to Complex Computing Problem (CCP) Mapping:

CCP Attribute	WP1 and some or all of WP2 to WP7:	FYDP to CCP Mapping How it is addressed in FYDP
Range of conflicting requirements	**WP1:** wide-ranging or Conflicting technical, engineering/computing and other issues	Security, autonomy and cost conflict. Stricter command validation slows scans, and local inference trades some model quality for lower cost.
Depth of analysis required	**WP2:** no obvious solution	We found no published deterministic safety layer for autonomous IoT/OT pentesting agents, so the AST rule set and correction loop must be designed from scratch.
Depth of knowledge required	**WP3:** one or more of **ACM Knowledge Ara**	Combines AI/LLM agents, network security and pentesting, static analysis (AST parsing) and web engineering.
Familiarity of issues	**WP4:** Involve infrequently encountered issues	Involves LLM hallucination in security planning, deterministic checking of agent actions, and reliable local LLM inference.

Extent of applicable codes	**WP5:** outside problems encompassed by standards and codes of practice	No standard covers pre-execution validation of LLM agent actions, so we define our own rule schema, guided by related static-analysis work.
Extent of stake-holder involvement and conflicting requirements	**WP6:** diverse groups of stakeholders with widely varying needs	Stakeholders are the supervisory panel, security researchers and, indirectly, IoT/OT operators, who differ in risk tolerance and in how much autonomy they accept.
Interdependence	**WP7:** many component parts or sub-problems	The Planner, Safety-Critic, Executor and dashboard depend on each other. A change to the rule schema affects the retry logic, command format and audit display.

14. Gantt Chart



References:

[1] K. Swinea, K. Aryal, L. Praharaj, and M. Gupta, "VEXAIoT: Autonomous IoT Vulnerability EXploitation using AI Agents," arXiv:2607.09653v1 [cs.CR], Jul. 2026. (Baseline paper.)

[2] W. Hua et al., "TrustAgent: Towards Safe and Trustworthy LLM-based Agents," arXiv:2402.01586 [cs.CL], 2024.

[3] L. Jia et al., "VESTA: A Fully Automated Scenario Generation and Safety Evaluation Framework for LLM Agents," arXiv:2606.08531 [cs.AI], Jun. 2026.

[4] K. Hammar, T. Alpcan, and E. C. Lupu, "Hallucination-Resistant Security Planning with a Large Language Model," arXiv:2602.05279 [cs.AI], Feb. 2026 (accepted to IEEE/IFIP NOMS 2026).

[5] C. Huang, X. Huang, and A. Milani Fard, "Auditing MCP Servers for Over-Privileged Tool Capabilities," arXiv:2603.21641 [cs.CR], Mar. 2026.

[6] J. Knoop and H. Holtmann, "Private LLM Inference on Consumer Blackwell GPUs: A Practical Guide for Cost-Effective Local Deployment in SMEs," arXiv:2601.09527 [cs.LG], Jan. 2026.

15. Details of Project Team:

S. No.	Name of the Student	IU Regn No	CGPA	Signature
1	Ayesha Khan	IU02-0323-0540	3.54	
2	Maryum Mughal	IU02-0122-0296	3.45	
3	Amaan Khan	IU02-0122-0589	2.59	
4	Muhammad Damil Khan	IU02-0123-0215	2.93	

16. Details of Supervisor (s)/ Industrial Advisor:

	Name	Designation & Department	Contact No.	Signature
Supervisor	Muhammad Asif Sheikh	Faculty of Computer Science Department	+92 332 3247812	
Industrial Advisor	Umair Ali	Manager Digital, Design, Data & Delivery at National Foods Limited	+92 301 8293518	

17. For office us only:

☐ Proposal Approved	☐ Not Approved	☐ Returned for Clarification / Modification	
Comments (if any):			
Project Serial No.		Date:	
Signature FYDP Coordinator		Signature Chairperson	
Signature Associate Dean / Dean			